

1 Mesures de sécurité proposées pour la plateforme e-commerce de dev.com

Afin de réduire les risques de cyberattaques, dev.com doit mettre en place un ensemble de **mesures techniques, organisationnelles et procédurales** couvrant l'ensemble de l'architecture (client, serveur web, application, base de données).

1. Renforcement du contrôle d'accès (A01)

- Mise en œuvre du **principe du moindre privilège**.
- Séparation claire des rôles (client, administrateur, opérateur).
- Vérification systématique des autorisations côté serveur.
- Protection des ressources sensibles (URL, API, fichiers).

2. Sécurisation de l'authentification (A07)

- Mise en place de l'**authentification multifacteur (MFA)**.
- Gestion sécurisée des sessions (cookies HttpOnly, Secure).
- Protection contre les attaques par force brute (rate limiting).
- Politique de mots de passe robustes.

3. Chiffrement des données sensibles (A02)

- Utilisation obligatoire de **HTTPS (TLS)** pour toutes les communications.
- Chiffrement des mots de passe avec des algorithmes forts (bcrypt, Argon2).
- Chiffrement des données sensibles stockées en base (cartes, identifiants).

4. Protection contre les injections (A03)

- Utilisation de **requêtes préparées / ORM**.
- Validation et filtrage strict des entrées utilisateur.
- Désactivation de l'exécution de code dynamique non contrôlé.
- Protection contre XSS (escaping, CSP).

5. Sécurisation de la conception applicative (A04)

- Intégration de la **sécurité dès la phase de conception** (Security by Design).

- Réalisation de **modélisation des menaces (Threat Modeling)**.
- Séparation des couches (présentation, logique métier, données).

6. Bonne configuration des serveurs et services (A05)

- Désactivation des services inutiles.
- Suppression des configurations par défaut.
- Mise en place de **firewalls applicatifs (WAF)**.
- Protection contre XXE (désactivation XML externe).

7. Mise à jour et gestion des composants (A06)

- Mise à jour régulière des frameworks, bibliothèques et serveurs.
- Surveillance des vulnérabilités connues (CVE).
- Utilisation de dépôts fiables et contrôlés.

8. Journalisation et surveillance (A09)

- Journalisation des événements critiques (authentification, erreurs).
- Centralisation des logs.
- Mise en place d'alertes en temps réel (SIEM).
- Conservation des journaux pour l'investigation.

9. Sécurisation des mises à jour et CI/CD (A08)

- Vérification de l'intégrité des mises à jour.
- Signature du code et des packages.
- Contrôle des pipelines CI/CD.
- Limitation des accès aux outils DevOps.

10. Protection contre les attaques SSRF (A10)

- Validation stricte des URL côté serveur.
- Blocage des accès internes non autorisés.

- Filtrage réseau entre services.
- Isolation des serveurs applicatifs.

11. Sensibilisation et formation

- Formation régulière des développeurs et administrateurs.
- Sensibilisation aux bonnes pratiques OWASP.
- Simulations d'attaques (tests d'intrusion).

12. Sauvegardes et plan de reprise

- Sauvegardes régulières et chiffrées.
- Tests de restauration.
- Plan de reprise après incident (PRA).

2 Processus de gestion des vulnérabilités techniques

Le **processus de gestion des vulnérabilités** chez dev.com doit être **continu et structuré** :

1. **Identification**
 - Scans automatisés des vulnérabilités.
 - Audits de sécurité et tests d'intrusion.
2. **Analyse et évaluation**
 - Évaluation de la gravité (CVSS).
 - Priorisation selon l'impact métier.
3. **Correction**
 - Application de correctifs (patches).
 - Refonte du code vulnérable.
 - Mise à jour des configurations.
4. **Vérification**
 - Tests après correction.

- Validation par scans ou audits.

5. Suivi et amélioration continue

- Documentation des incidents.
- Amélioration des pratiques de développement sécurisé.

3 Outils utilisés pour la sécurité

- **Analyse de code** : SonarQube, Checkmarx
- **Tests d'intrusion** : OWASP ZAP, Burp Suite
- **Scan de vulnérabilités** : Nessus, OpenVAS
- **Gestion des dépendances** : Dependabot, Snyk
- **Surveillance et logs** : ELK Stack, Splunk
- **Protection applicative** : WAF (ModSecurity, Cloudflare)

Conclusion

La sécurisation de la plateforme e-commerce de **dev.com** repose sur une **approche globale**, combinant :

- des **mesures techniques solides**,
- une **conception sécurisée**,
- une **gestion proactive des vulnérabilités**,
- et une **surveillance continue**.

L'alignement sur le **OWASP Top 10** permet de réduire significativement les risques de cyberattaques et de protéger les données sensibles des clients.

Voici une **réponse claire, structurée et concise**, adaptée à un **examen / devoir universitaire** (5 points).

Supervision des réseaux et systèmes

La **supervision des réseaux et systèmes** consiste à **surveiller en continu** l'état, la performance et la disponibilité des équipements (serveurs, routeurs, switches, applications, services) afin de **détecter rapidement les incidents** et garantir la continuité de service.

1 Principaux mécanismes de supervision

1. Supervision active

- Le système de supervision **interroge périodiquement** les équipements.
- Exemple : ping, requêtes SNMP, vérification d'un service web.
- Permet de mesurer la **disponibilité** et le **temps de réponse**.

2. Supervision passive

- Les équipements **envoient spontanément** des événements ou alertes.
- Exemple : traps SNMP, messages Syslog.
- Utilisée pour la **détection immédiate des incidents**.

3. Collecte de métriques

- Surveillance des ressources : CPU, mémoire, disque, bande passante.
- Analyse des performances et détection des anomalies.

4. Gestion des alertes

- Déclenchement d'alertes (mail, SMS, tableau de bord) en cas de dépassement de seuil.
 - Aide à une réaction rapide des administrateurs.
-

2 Principaux protocoles de communication

1. SNMP (Simple Network Management Protocol)

- Protocole **le plus utilisé** en supervision réseau.
- Fonctionne avec :
 - **Agent SNMP** sur l'équipement
 - **Manager SNMP** (outil de supervision)
- Permet de :
 - Lire des informations (CPU, trafic, état des interfaces)
 - Recevoir des alertes (**SNMP Traps**)
- Versions : SNMPv1, v2c, **v3 (sécurisé)**

2. Syslog

- Protocole de **journalisation centralisée**.
- Les équipements envoient leurs logs vers un serveur Syslog.
- Utile pour :
 - Détection d'erreurs
 - Audit et investigation

3. ICMP

- Utilisé pour tester la **connectivité** et la **disponibilité**.
- Exemple : commande **ping**.
- Permet de détecter les pannes réseau.

4. WMI (Windows Management Instrumentation)

- Spécifique aux environnements **Windows**.
- Supervision des services, processus et performances système.

5. HTTP / HTTPS

- Vérification de la disponibilité des **applications web**.
 - Test des réponses des services (codes HTTP).
-

3 Exemples de produits de supervision

Outils open source

- **Nagios** : supervision réseau et système
- **Zabbix** : supervision complète (réseau, serveurs, applications)
- **Centreon** : basé sur Nagios, très utilisé en entreprise
- **Prometheus** : collecte de métriques et supervision moderne
- **Grafana** : visualisation des données

Outils commerciaux

- **SolarWinds**
- **PRTG Network Monitor**
- **ManageEngine OpManager**
- **IBM Tivoli Monitoring**

Conclusion

La supervision des réseaux et systèmes repose sur :

- des **mécanismes actifs et passifs**,
- des **protocoles standards** comme SNMP, Syslog et ICMP,
- et des **outils spécialisés** permettant de garantir la disponibilité, la performance et la sécurité du système d'information.

Si tu veux, je peux te fournir :

- une **version encore plus courte (réponse manuscrite)** 
- un **tableau récapitulatif**
- ou une **fiche de révision** 